
Guide de raccordement des applications derrière les SSO du ST(SI)²

Date de création du document	25 mars 2019
Date de la dernière modification	23 avril 2019

Objet du document

Ce document est destiné aux chefs de projets qui souhaitent raccorder leurs applications derrière un SSO administré par le ST(SI)². Il explique également les différents modes de fonctionnement du SSO (authentification LDAP, SAML, reverse proxy). Il détaille également le processus de raccordement des applications ainsi que les différentes étapes à respecter.

1 Processus

Le raccordement d'une application derrière un SSO se fait selon un processus en plusieurs étapes. Une fois la première prise de contact effectuée, et grâce à ce document, le chef de projet définit son besoin (mode de raccordement, entêtes HTTP, profils, règles d'accès, ...) auprès des administrateurs SSO. La première opération est le raccordement à la plate-forme de qualification (URL en .ppspo).

Lorsque l'application est qualifiée, le raccordement peut s'effectuer sur le SSO de production à **l'identique** du montage en qualification. C'est-à-dire qu'il ne peut y avoir de différence entre les configurations des deux plateformes pour des raisons évidentes de maintenabilité.

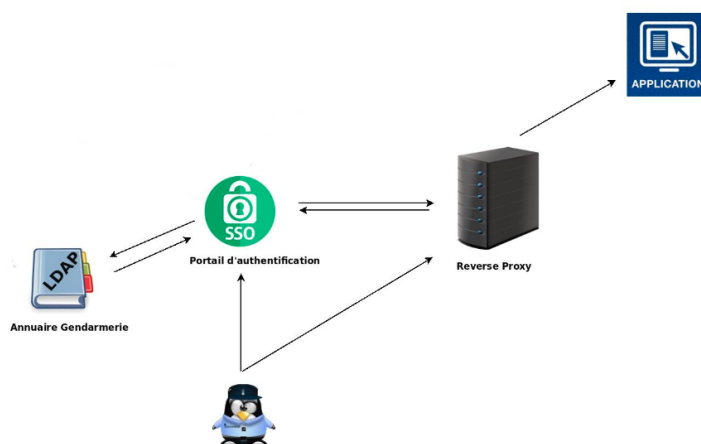
Les administrateurs SSO ont un rôle de conseil auprès des chefs de projets, et ce, à toutes les phases du raccordement et notamment à propos du nombre de profils applicatifs et des règles d'accès. Ils peuvent, le cas échéant, être amenés à refuser de raccorder des applications dont les profils seraient trop nombreux ou les règles d'accès trop contraignantes. La simplicité pour les utilisateurs et les gérants d'habilitations doit être la priorité.

2 Principe de fonctionnement du SSO

2.1 Mode reverse Proxy

Dans le mode reverse proxy, les applications sont protégées par le SSO. C'est-à-dire que les utilisateurs ne peuvent y accéder sans passer par les reverse proxy.

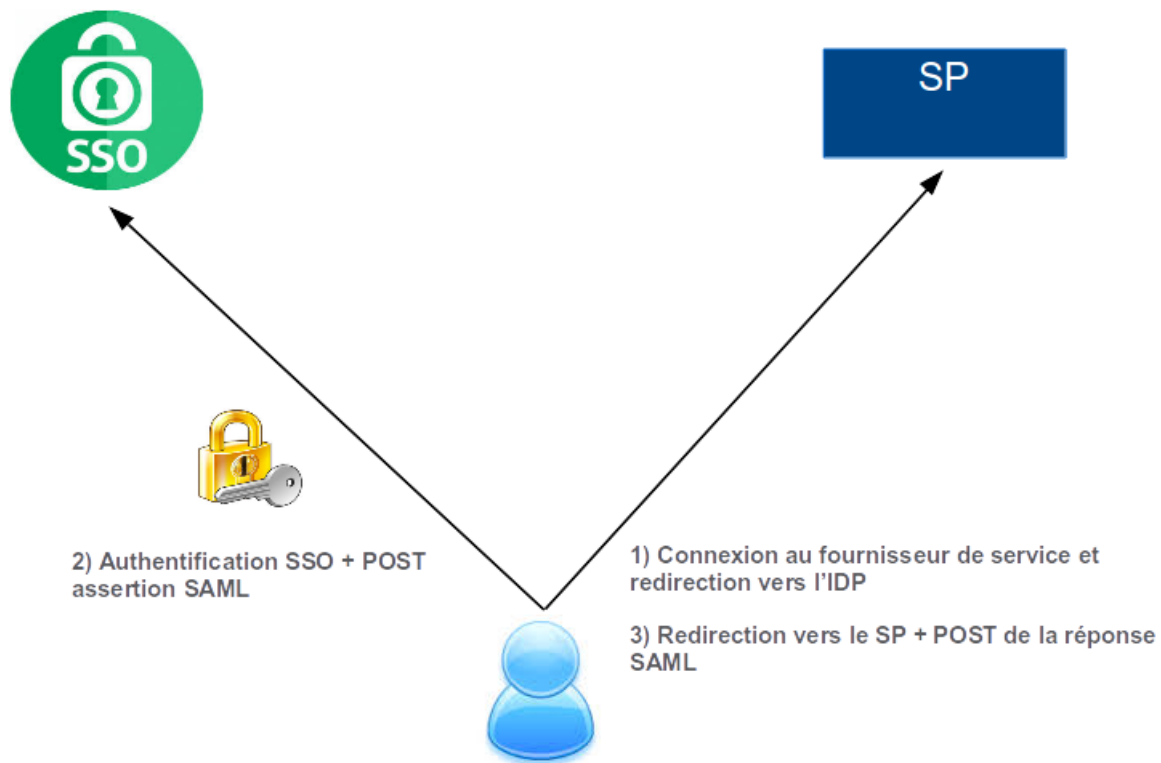
Un utilisateur qui tente d'accéder à une application avec une URL de type mon-appli.sso.* est redirigé vers les reverse proxy. S'il possède un cookie de session valide et si les règles d'accès à l'application le permettent, il peut alors accéder à l'application. Sinon, il est redirigé vers le portail (auth.sso) pour s'authentifier. Une fois authentifié, il est à nouveau redirigé vers les reverse proxy, et en fonction de ses droits, vers l'application.



Le chiffrement est porté par plusieurs répartiteurs de charge. Les reverse proxy embarquent le code du handler (agent logiciel chargé du contrôle d'accès et garantissant la traçabilité des accès). Ces traces sont conservées pour une durée de 3 ans.

2.2 Mode fédération des identités (SAML)

Dans le mode fédération des identités, on distingue le fournisseur d'identité (IDP pour Identity Provider) qui authentifie l'utilisateur et le fournisseur de service (SP pour Service Provider) qui est l'application qui délègue l'authentification à un tiers de confiance, en l'occurrence, l'IDP. Le protocole mise en œuvre étant SAML, le mode fédération des identités est appelé mode SAML par abus de langage.



Lorsque l'utilisateur arrive sur le SP, il est redirigé vers son SSO, soit de manière automatique soit par choix d'un IdP par l'utilisateur. Le SP fournit une assertion SAML (POST SAML_REQUEST) signée par le SP.

L'utilisateur s'authentifie et poste l'assertion en même temps. Le SSO IDP forge la réponse SAML (POST SAML_RESPONSE) et renvoie l'utilisateur vers le SP qui vérifie la réponse et considère l'utilisateur comme authentifié.

En SAML, les flux réseau ne passent plus par les reverse proxy du SSO ce qui implique que :

- le chiffrement doit être porté par l'application (mise en place d'un certificat SSL);
- la traçabilité des connexions sera assurée par l'application.

À noter qu'ici, Proxyma et Cheops NG sont uniquement des IdP.

Cas particulier de NeoGend:

Lorsque l'on clique sur la carte, le proxy entrant de Neogend intercepte la requête vers authssl et la modifie pour ajouter l'uid dans un entête HTTP qui permet d'authentifier l'utilisateur. On parle

d'authentification en mode Slave car le SSO fait confiance à Neogend et c'est bien NeoGend qui authentifie l'utilisateur sur la base du certificat client détenu. Or, le proxy entrant NeoGend supprime l'assertion SAML lors de l'envoi vers authssl ce qui entraîne une erreur lors de l'authentification. Pour que cela fonctionne, le proxy entrant NeoGend doit donc jouer la méthode POST avec le contenu de l'assertion SAML sans altérer cette partie de la requête.

3 Institution ou SSO concerné

Choix de la plateforme SSO :

- GN → Proxyma → sso.gendarmerie.fr (sso ou dvssso ou formssso ou ppsso) ;
- PN → CheopsNG → sso.police.fr (sso ou ppsso, la formation est derrière le SSO de production) ;
- GN, PN, PREF ou PP → PSI (SSO fédéré) → sso.psi.minint.fr (sso ou ppsso). Attention, PSI est uniquement un fournisseur de service (Voir SAML) ;
- Autres (Justice, Finances, Douanes, ...) → Judiweb (SSO en DMZ ADER/RIE) → gendarmerie.interieur.ader.gouv.fr (uniquement prod) ;
- Internet GN → Curasso → sso.gendarmerie.interieur.gouv.fr / Espresso → secure.gendarmerie.interieur.gouv.fr (uniquement prod).

4 Enregistrement DNS SSO

Les administrateurs se chargent de demander les enregistrements DNS de la forme suivante :
Format : mon-appli.<plateforme_sso>.institution.fr

Exemples :

- mon-appli.ppsso.police.fr
- mon-appli2.sso.gendarmerie.fr

5 Règles d'accès

Dans le cas du mode reverse proxy, le contrôle d'accès aux applications peut être effectué par le SSO. On écrit alors le ou les profils des personnels autorisés à accéder à l'application dans les règles d'accès du virtual host.

Il est possible de déclarer des règles différentes en fonction d'une ou plusieurs URL. Les règles sont des expressions régulières ou logiques calculées en fonction des attributs choisis.

Format : URL → RULE

Exemples :

/ → accept
/appli → codeUnite eq "12156"

5.1 Côté GN

L'attribution des droits se fait de manière automatique en fonction des règles définies dans le RDA (référentiel des droits d'accès) via des groupes LDAP. A noter que l'annuaire LDAP de préprod se synchronise avec l'annuaire de prod. Il n'y a donc aucune différence entre les deux environnements.

Contact : droits-acces-gn@gendarmerie.interieur.gouv.fr.

5.2 Côté PN

Les droits sont distribués via le gérant d'habilitations GeHa-Web de Prod ou PréProd. Pour chaque profil applicatif, la direction d'application doit fournir:

- une description synthétique du profil ;
- les services autorisés à attribuer le profil à leurs membres ;
- les modalités d'attribution dudit profil.

Contact : `admin-cheops@gendarmerie.interieur.gouv.fr`.

6 Entêtes HTTP

Une fois l'utilisateur authentifié, le SSO peut transmettre des attributs via des entêtes HTTP en mode ReverseProxy ou dans l'assertion SAML en fonction du mode choisi.

La liste des attributs disponibles est consultable à l'URL `https://auth.<plateforme_sso>/groups.pl` ou `https://auth.<plateforme_sso>/checkuser`

Format : Clé → Valeur

Exemples :

ID → nigend

SERVICE → codeUnite

NAME → nom

7 Cible du virtual host

L'application doit être joignable soit par une adresse IP soit par un nom d'hôte afin que les reverse proxy transmettent les requêtes des utilisateurs vers l'application.

Dans le cas d'un nom d'hôte, il s'agit d'un enregistrement DNS dans l'IPMS pris par le chef de projet.

Format : @IP du VS ou enregistrement DNS de l'application.

Exemples :

IP : 10.226.129.131

Nom : mon-appli.gend, mon-appli.ppgend, ...

Port : 80, 8080, ...

8 Sécurité

Les chefs de projets doivent veiller à n'autoriser l'accès au(x) serveur(s) cible(s) qu'à travers les serveurs du SSO. Sur les serveurs applicatifs, il faut modifier les configurations des serveurs web pour n'autoriser que les connexions provenant des adresses IP des reverse proxy du SSO concerné.

8.1 Exemple de conf Apache

```
<VirtualHost *:80>
  ServerName mon-appli.gend
    <Location />
      Order deny,allow
      Deny from all
      Allow from <IP Sortante des reverse proxy>
      Allow from 127.0.0.1
    </Location>
</VirtualHost>
```

8.2 Exemple de conf Nginx

```
server {
  listen 80;
  server_name mon-appli.gend;
  location / {
    allow <IP Sortante des reverse proxy>;
    allow 127.0.0.1;
    deny all;
  }
}
```

9 Résumé

9.1 Raccordement d'une application web en mode reverse proxy

Dans le cadre du raccordement d'une application en mode reverse proxy, il faut fournir aux administrateurs des SSO les éléments suivants :

- Plateforme SSO souhaitée ;
- nom DNS souhaité et IP/nom d'hôte+port dans l'IMPS de l'application cible ;
- règles d'accès ;
- profils applicatifs (noms, descriptions, modalités d'attribution) ;
- liste des entêtes HTTP à transmettre à l'application.

En retour, les administrateurs SSO fourniront les adresses IP des ReverseProxy SSO afin de sécuriser les serveurs applicatifs en n'autorisant l'accès qu'à partir du SSO.

9.2 Raccordement d'une application web en mode SAML

Dans le cadre du raccordement d'une application en mode SAML, il faut fournir aux administrateurs SSO les éléments suivants :

- les métadonnées de l'application ;
- les profils applicatifs (noms, descriptions, modalités d'attribution) ;
- les attributs à transmettre (équivalent des entêtes) souhaités.

En retour, les administrateurs SSO fourniront les métadonnées du SSO concerné pour le paramétrage du SP.

9.3 Contacts

Proxyma :

`admin-sso@gendarmerie.interieur.gouv.fr`

`droits-acces-gn@gendarmerie.interieur.gouv.fr`

CheopsNG :

`admin-cheops@gendarmerie.interieur.gouv.fr`

`admin-sso@gendarmerie.interieur.gouv.fr`

PSI :

`admin-sso@gendarmerie.interieur.gouv.fr`

Judiweb :

`admin-sso@gendarmerie.interieur.gouv.fr`

Curasso/Esspresso :

`admin-sso@gendarmerie.interieur.gouv.fr`